

PARALLAX

A Dual-Perspective Cybersecurity Training Platform with a Socratic
AI Mentor

Project Submitted in partial fulfillment for the degree of Bachelor of
Science in Cybersecurity

PREPARED BY

Mahmoud Allabadi
Rashed Alkurdi

2221558
0221992

SUPERVISED BY

Dr. Abdel Latif Abu-Dalhoun

King Abdullah II School of Information Technology
The University of Jordan

JUNE 2026 · v1.1.0-academic

ABSTRACT

PARALLAX is a cybersecurity training platform that places offensive and defensive perspectives inside a single causal loop. A student executes a real attack from a Kali Linux workspace against an isolated Docker target; the same action surfaces as defender telemetry — a ModSecurity web-application firewall and container logs shipped by Filebeat into Elasticsearch, then correlated by the backend SIEM engine — and appears in a Blue-Team event feed in well under two seconds. A Socratic AI mentor, gated by a bounded context builder, an input-redaction and response-sanitization layer, and a strict token cap, supplies hints rather than working exploits.

This report documents the system end to end: its requirements and architecture; the threat model that keeps the mentor from becoming an exploit-generation oracle; the three production scenarios (web, Active Directory, phishing) used for evaluation; the implementation of the frontend, backend, sandbox, telemetry, and mentor; and the test evidence that supports v1.0.0-rc1 as ready for instructor evaluation — 358 passing backend cases, sub-two-second attack-to-telemetry latency, 100% scenario-network isolation, and Lighthouse 91 performance / 100 accessibility. Appendices provide the full API surface, database schema, requirements traceability, deployment procedures, and scenario reference.

KEYWORDS

cybersecurity training · penetration testing · SOC analysis · Docker isolation · Socratic AI · SIEM · dual-perspective learning · FastAPI · React

CONTENTS

Introduction	6
Motivation	6
Problem statement	6
Contributions	7
Scope	7
Structure of this report	7
Background and Related Work	8
Cyber ranges and CTF platforms	8
Tutoring and Socratic guidance	8
Standards and frameworks	8
Why a new platform	9
Architecture	10
Requirements	10
The causal loop	11
Layered architecture	12
Data flow	13
Data model	14
Network isolation	15
Design decisions	16
Threat Model	17
Trust boundaries	17
Isolation guarantees	18
Kernel-level resource hardening	18
STRIDE analysis	18
Mentor guardrails	19
Audit and logging	20
Compliance mapping	20
Scenarios	21
Gated methodology	21
Scenario blueprint	22
SC-01 — NovaMed Healthcare Intermediate	22
SC-02 — Nexora Active Directory Advanced	23
SC-03 — Orion Phishing Intermediate	24
Scoring model	25
Implementation	26
Frontend	26
Backend	26
Sandbox and session lifecycle	27
The Red-to-Blue loop	28
AI mentor	29
Reporting and instructor analytics	29
Evaluation	30
Testing strategy	30
Headline evidence	30
Load and latency	31

Demo readiness	32
Reproducibility	32
Discussion	33
Limitations	33
Future work	33
Reflection	33
References	34
Appendix A — Repository Layout	35
Appendix B — Reproduce the Evaluation	37
Appendix C — API Reference	39
Route groups	39
Health and authentication	39
Scenarios and playbooks	40
Sessions	40
Notes, hints, scoring, reports	40
AI, SIEM, and WebSocket	41
Instructor	41
Appendix D — Database Schema	43
Storage responsibilities	43
Table columns	43
Migrations	44
Appendix E — Requirements Traceability	45
Functional requirements	45
Non-functional requirements	46
Appendix F — Deployment and Operations	47
Prerequisites	47
Environment variables	47
Local deployment	48
Production deployment (Caddy + sslip.io)	48
Operations and recovery	48

ABBREVIATIONS

AD	Active Directory
API	Application Programming Interface
CIDR	Classless Inter-Domain Routing
DFD	Data Flow Diagram
ERD	Entity-Relationship Diagram
JWT	JSON Web Token
KASIT	King Abdullah II School of Information Technology
LLM	Large Language Model
MITRE	MITRE ATT&CK adversary technique knowledge base
NIST	National Institute of Standards and Technology
PTES	Penetration Testing Execution Standard
PTY	Pseudo-terminal
ROE	Rules of Engagement
SIEM	Security Information and Event Management
SPN	Service Principal Name
WAF	Web Application Firewall
WS	WebSocket

CHAPTER 01

Introduction

The gap between offensive and defensive cybersecurity education, and how a shared sandbox closes it.

Motivation

Most cybersecurity curricula teach attack and defense in separate rooms — a penetration-testing course here, a SOC-analyst course there. Students graduate able to do one or the other but rarely see how a single keystroke on one side becomes an alert on the other. The penetration tester learns to launch an injection without watching the firewall log it; the analyst learns to read an alert without having generated one. The causal link between the two — the very thing a security professional must reason about every day — is left implicit. PARALLAX is built around that missing link. It runs a Red-Team workspace and a Blue-Team SIEM over the **same** session, so an action and its detection are visible at once. A student attacks an isolated target from a Kali terminal and, seconds later, sees the telemetry their action produced in a defender console. The platform turns “attack” and “defend” from two courses into two views of one event.

INSIGHT

The pedagogical wager: comprehension of either side deepens when the other side is visible in real time. The latency between the two surfaces is therefore not merely a performance metric — it is a learning-design constraint, which is why the sub-two-second budget recurs throughout this report.

Problem statement

Existing training platforms are effective but single-perspective. Offensive ranges drop a learner onto a vulnerable host and reward a captured flag; defensive platforms replay captured telemetry and reward a correct triage. In neither case does the learner author the cause and observe the effect in the same place and time. A platform that closes the loop must solve three problems simultaneously: it must let attack and defense share one sandboxed session without their state bleeding together; it must surface defensive telemetry fast enough to feel causal; and it must offer guidance that scaffolds reasoning without handing over the exploit.

Contributions

- A working dual-perspective lab in which Red-Team actions against isolated Docker targets produce live Blue-Team telemetry over a single shared session.
- A Socratic AI mentor with enforced guardrails — bounded context, secret redaction, response sanitization, and a token cap — that never emits payloads.
- Three calibrated, self-contained scenarios (web application, Active Directory, phishing) with curated MITRE ATT&CK coverage and gated methodology.
- A complete instructor surface: live session monitoring, per-student metrics, AI-usage review, and grade export.
- An automated test suite (359 cases) and an evaluation a reviewer can re-run in minutes, packaged as a single-node Docker Compose stack.

Scope

The active scope is exactly three scenarios — SC-01, SC-02, and SC-03 — deployed on a single Docker host. The platform is designed for a university lab and a graduation defense, not multi-tenant production load. Multi-node operation, additional scenarios, and declarative scenario authoring are future work (Chapter 8). Every offensive capability operates only against the isolated scenario containers; the platform never targets real systems.

Structure of this report

Chapter 2 surveys related work and frameworks. Chapter 3 presents requirements and the system architecture. Chapter 4 documents the threat model and the mentor's guardrails. Chapter 5 describes the three scenarios and the scoring model. Chapter 6 covers the implementation of every layer. Chapter 7 reports the evaluation evidence. Chapter 8 discusses limitations and future work. The appendices give the full API surface, database schema, requirements traceability, and deployment procedures.

CHAPTER 02

Background and Related Work

What cybersecurity training offers today, the frameworks that anchor it, and what PARALLAX is reacting against.

Cyber ranges and CTF platforms

Hosted offensive ranges such as Hack The Box [1] and TryHackMe [2] teach attack skills through deliberately vulnerable machines. A learner enumerates a host, finds a flaw, exploits it, and submits a flag. These platforms excel at building offensive intuition and have large content libraries, but the defender's view is absent: the learner never sees the log, alert, or analyst decision their action would have produced.

Defensive platforms invert the emphasis. CyberDefenders [3] and similar blue-team ranges hand the learner captured telemetry — packet captures, event logs, SIEM exports — and reward correct investigation and triage. Here the attacker's view is absent: the telemetry is pre-recorded, so the learner cannot change the cause and watch the effect move.

Intentionally vulnerable applications such as OWASP Juice Shop [4] are excellent attack targets but ship no defensive telemetry pipeline at all. In every case the two perspectives live in separate tools.

Tutoring and Socratic guidance

Decades of work on intelligent tutoring systems show that learners improve most when a system prompts their reasoning rather than supplying answers. A tutor that hands over the solution short-circuits the very struggle that produces learning. PARALLAX applies this directly: its AI mentor is constrained to Socratic hints and is explicitly forbidden from returning a working exploit. The mentor nudges the learner toward the next question — “what does this service version tell you?” — instead of printing the payload. Chapter 4 documents the guardrails that make this constraint provable rather than aspirational.

Standards and frameworks

Scenario design and assessment are anchored in established references rather than invented rubrics:

FRAMEWORK	ROLE IN PARALLAX
OWASP Top 10 [5]	Vulnerability classes for the SC-01 web scenario.
OWASP WSTG [6]	Testing methodology for web-application assessment.
MITRE ATT&CK [7]	Technique mapping for every scenario and SIEM event.
NIST CSF [8]	Identify–Protect–Detect–Respond framing for the Blue-Team track.
PTES [9]	Phase ordering for the gated offensive methodology.

Figure 2 · 1 — Frameworks that anchor PARALLAX's scenario and assessment design

Why a new platform

The gap is the **causal link**. No widely used platform lets a student attack and simultaneously watch the defender's telemetry over one shared session, with a guarded tutor in the loop. PARALLAX targets exactly that intersection: it keeps the content quality and flag-driven motivation of an offensive range, adds the real telemetry and triage workflow of a defensive range, and binds them to one session so cause and effect are co-located in space and time.

PLATFORM	Attack	Defense	Mentor	Reset
Hack The Box	✓	—	—	—
TryHackMe	✓	partial	—	—
CyberDefenders	—	✓	—	—
OWASP Juice Shop	✓	—	—	—
PARALLAX	✓	✓	✓	8s

Figure 2 · 2 — Existing platforms against PARALLAX's design goals

CHAPTER 03

Architecture

From requirements to a three-surface causal loop: the views, the data, and the trade-offs that made it possible.

Requirements

The platform's requirements were derived from the KASIT project guidelines, the gap analysis in Chapter 2, and the safety constraints inherent to a security trainer. The functional core is small and sharp:

ID	REQUIREMENT
FR-AUTH	Register and authenticate students; gate instructor operations by role.
FR-SCEN	List and run the active scenarios SC-01, SC-02, SC-03.
FR-SESS	Start, track, and end Red- and Blue-Team sessions over shared state.
FR-ROE	Require rules-of-engagement acknowledgement before active work.
FR-TERM	Provide a browser terminal bound to an isolated Kali container.
FR-SIEM	Show Blue-Team telemetry causally linked to scenario activity.
FR-NOTE	Let students capture tagged findings and evidence notes.
FR-HINT	Provide bounded, Socratic AI hints with fallback behavior.
FR-GATE	Enforce methodology gates and scenario phases.
FR-SCORE	Score progress from milestones, hints, time, and adherence.
FR-REPORT	Generate a debrief and examiner-ready report from session data.
FR-INST	Provide instructor analytics, live monitoring, and grade export.

Figure 3 · 1 — Core functional requirements

The non-functional requirements that shape the design most are safety (scenario networks isolated from the internet), responsiveness (the sub-two-second attack-to-telemetry budget), portability (a single-node Docker deployment an examiner can stand up locally), and reliability (health and readiness checks for demo recovery). Appendix E traces every requirement to its implementation and test evidence.

The actors and their goals are summarized in the use-case model:

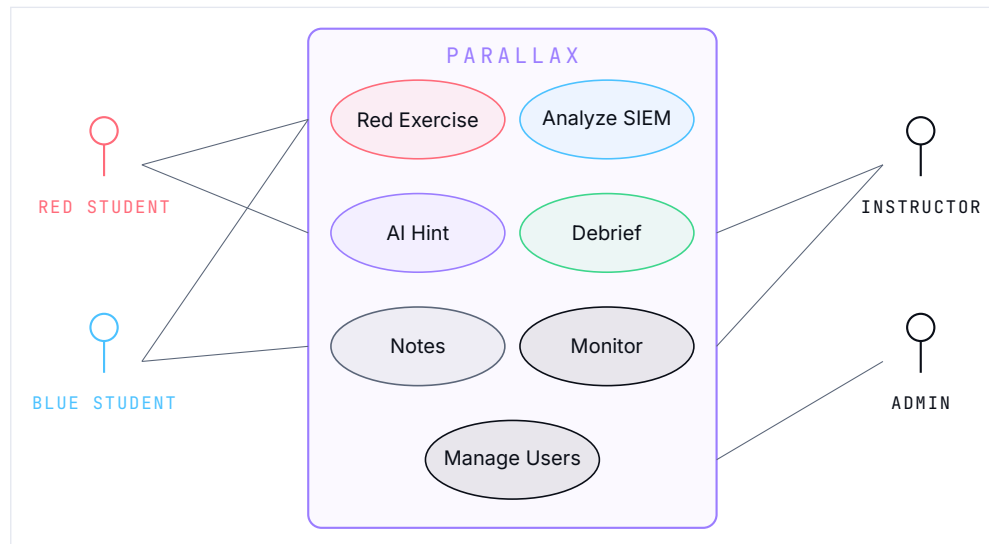


Figure 3 · 2 — PARALLAX use-case model: four actors over one shared system

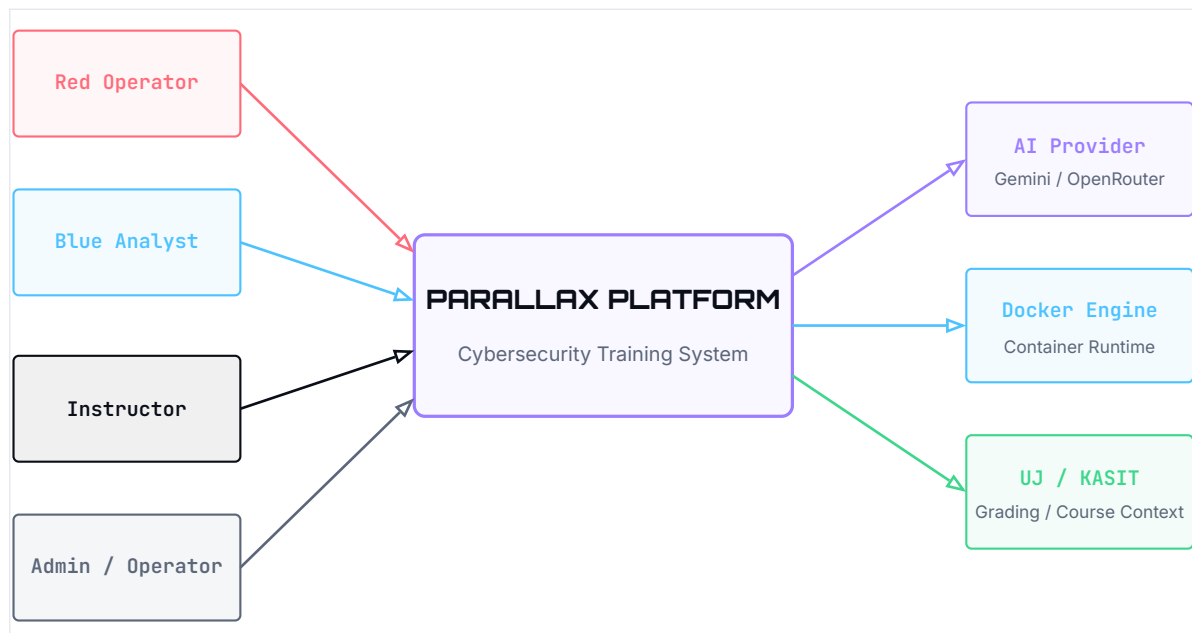


Figure 3 · 3 — PARALLAX C4 system context diagram: high-level boundaries and interactions

The causal loop

The system's central idea is a single loop closed between an attacker workspace, a defender SIEM, and an AI mentor. The mentor watches without intervening; the SIEM observes without participating; the attacker acts against a sandbox that resets between sessions. Detection is performed by a ModSecurity WAF and container logs shipped through Filebeat into Elasticsearch, then correlated by the backend SIEM engine — there is no separate network sensor.

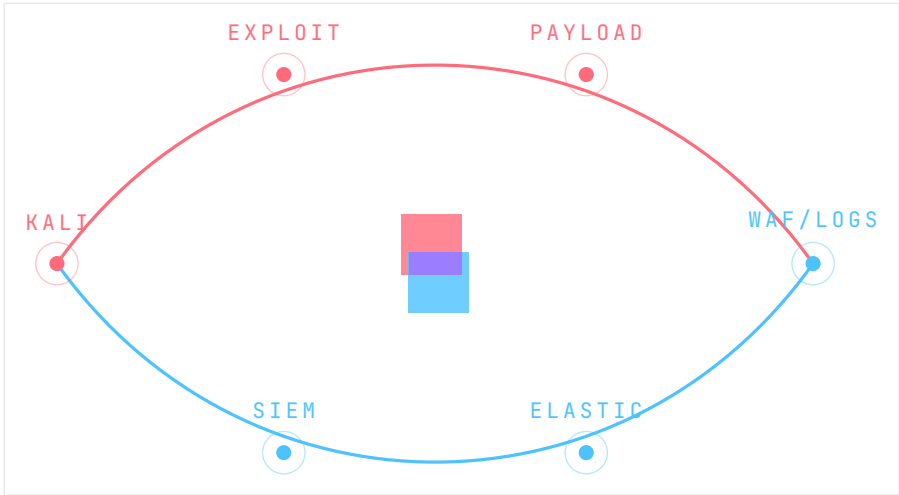


Figure 3 · 4 — Causal loop between attack, detection, and learning surfaces

Layered architecture

The runtime is a five-layer stack. Each layer is independently testable; the boundaries are HTTP, a WebSocket, or a Docker network — never a shared in-process object. The browser runs React [10] built with Vite [11]; the gateway is FastAPI [12]; durable state is PostgreSQL [13] with Redis [14] for realtime state; telemetry rides Filebeat into Elasticsearch [15], [16]; everything is orchestrated by Docker Compose [17].

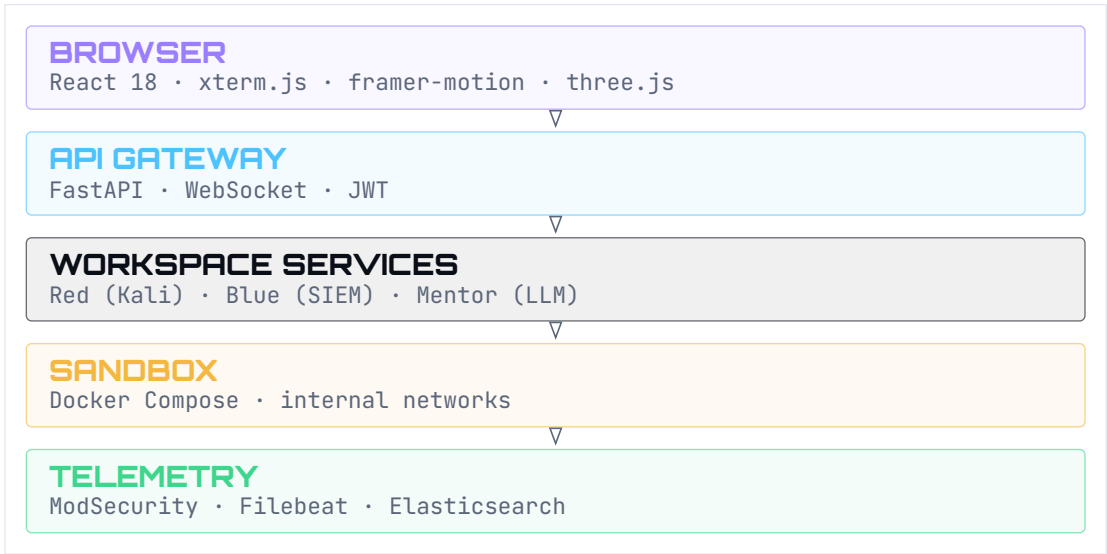


Figure 3 · 5 — Five-layer runtime architecture

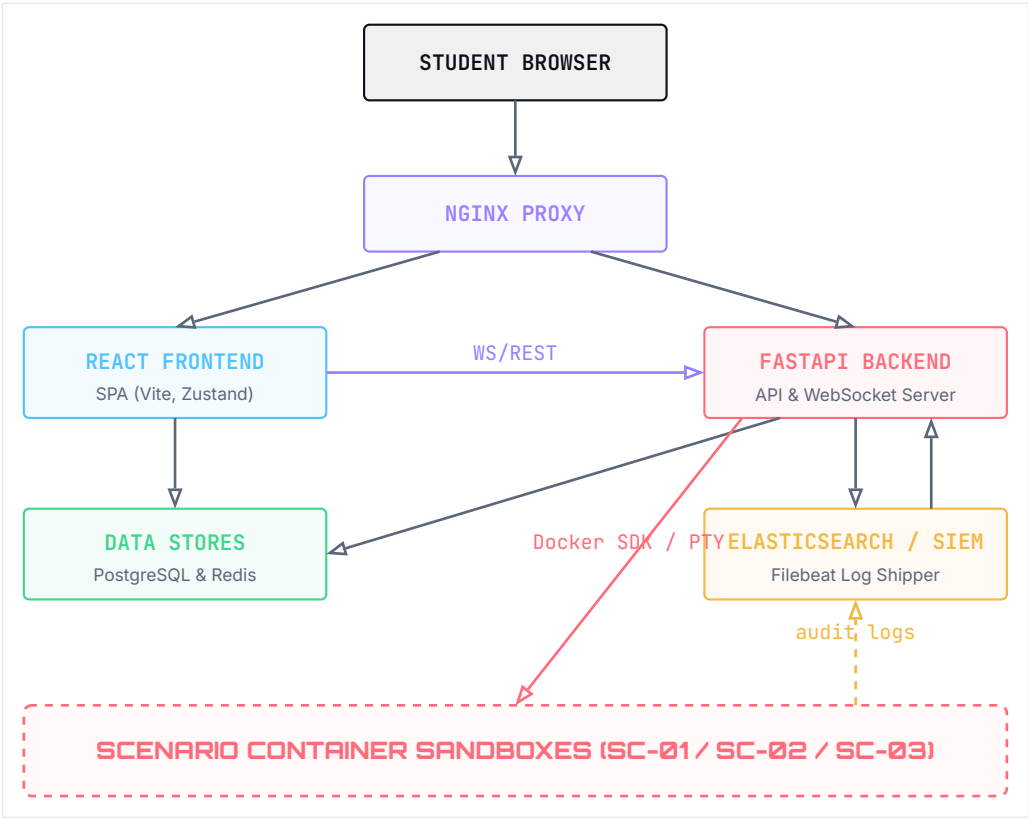


Figure 3 · 6 — PARALLAX C4 container diagram: system containers, protocols, and data routes

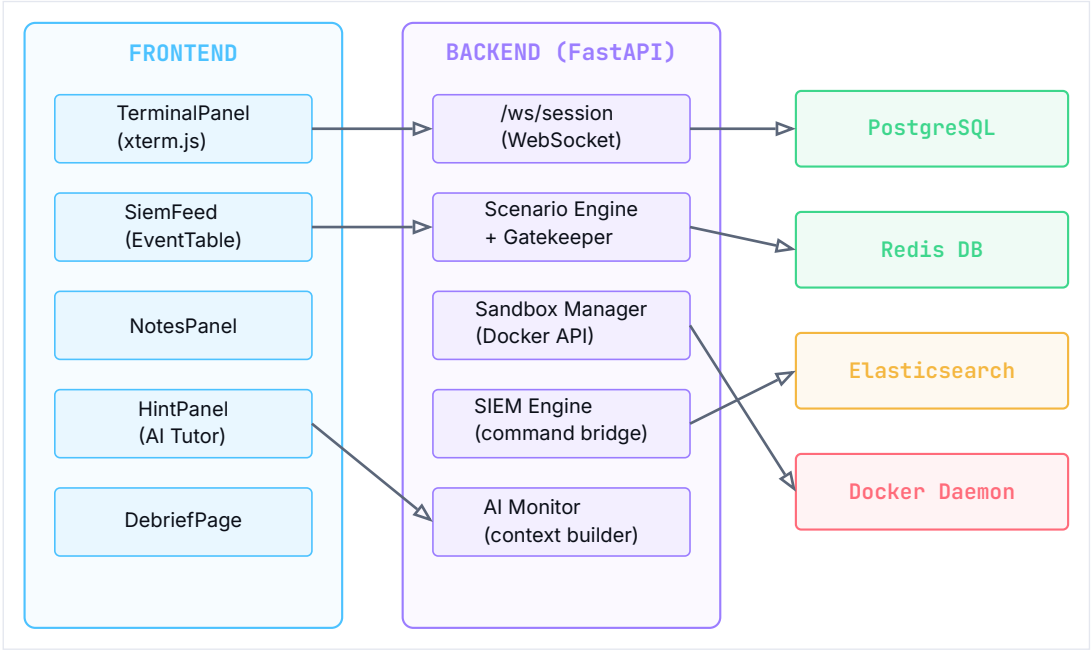


Figure 3 · 7 — Detailed component interaction model across frontend, backend, and data layers

Data flow

The platform has two data paths. Structured request-response traffic (login, scenario listing, session start, notes, scoring, reports) flows over REST; low-latency, event-driven traffic (terminal I/O, readiness, hints, SIEM events) flows over a WebSocket. The backend is the single process that touches every data store and the Docker engine.

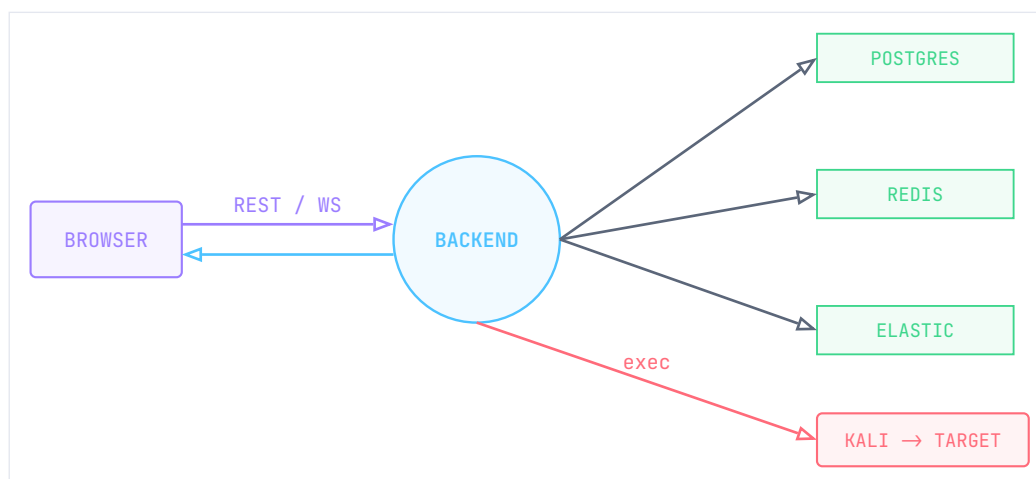


Figure 3 · 8 — Level-0 data flow across browser, backend, stores, and sandbox

Data model

A session is the unit of work: one student, one scenario, one role. It anchors notes, command metadata, SIEM events, triage decisions, AI-interaction metadata, and auto-detected evidence. The platform stores command **metadata** and curated evidence rather than full raw terminal output, keeping the database focused on learning evidence.

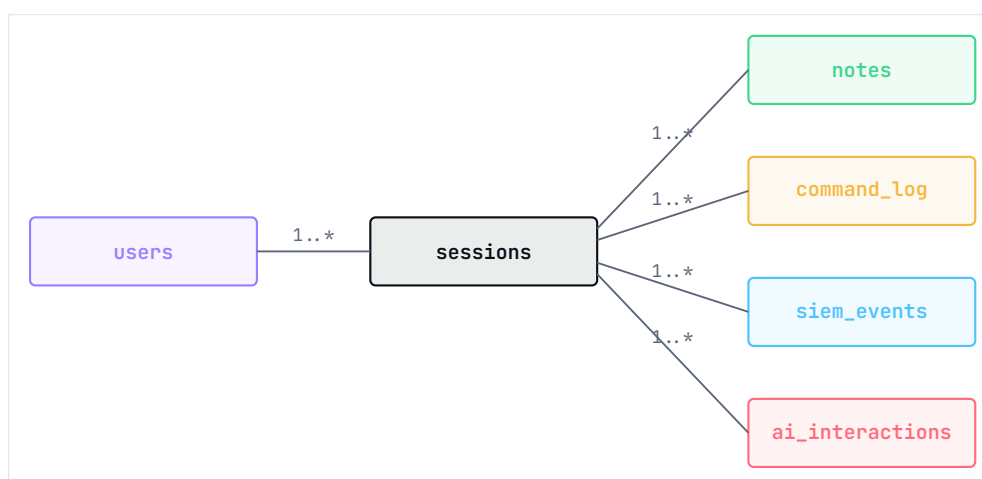


Figure 3 · 9 — Core entity relationships (full schema in Appendix D)

TABLE	PURPOSE
users	Identity, role, skill level, onboarding state.
sessions	Scenario, role, methodology, phase, score, ROE, sandbox IDs.
notes	Tagged findings and methodology notes.
command_log	Command metadata, tool, phase, SIEM trigger, hint flag.
siem_events	Events shown to Blue Team; severity, MITRE technique, source.
siem_triage	Analyst classification and notes per event.
ai_interactions	Hint/debrief metadata: tokens, model, latency, fallback, flag.

TABLE	PURPOSE
auto_evidence	Evidence summaries detected from command output patterns.
user_activity	Audit/activity feed for classroom monitoring.
containment_actions	Simulated Blue-Team response actions.

Figure 3 · 10 — Persistent tables and their role

Network isolation

Each scenario runs in its own Docker network, declared `internal: true`, with no route to the internet or to the other scenarios [18]. The attacker workspace is multiplexed: a single Kali container is attached to one scenario network at a time, never to two at once. Core services share a separate `172.30.0.0/24` bridge. Chapter 4 details the guarantees this buys.



Figure 3 · 11 — Three isolated scenario networks; dashed barriers are unrouteable

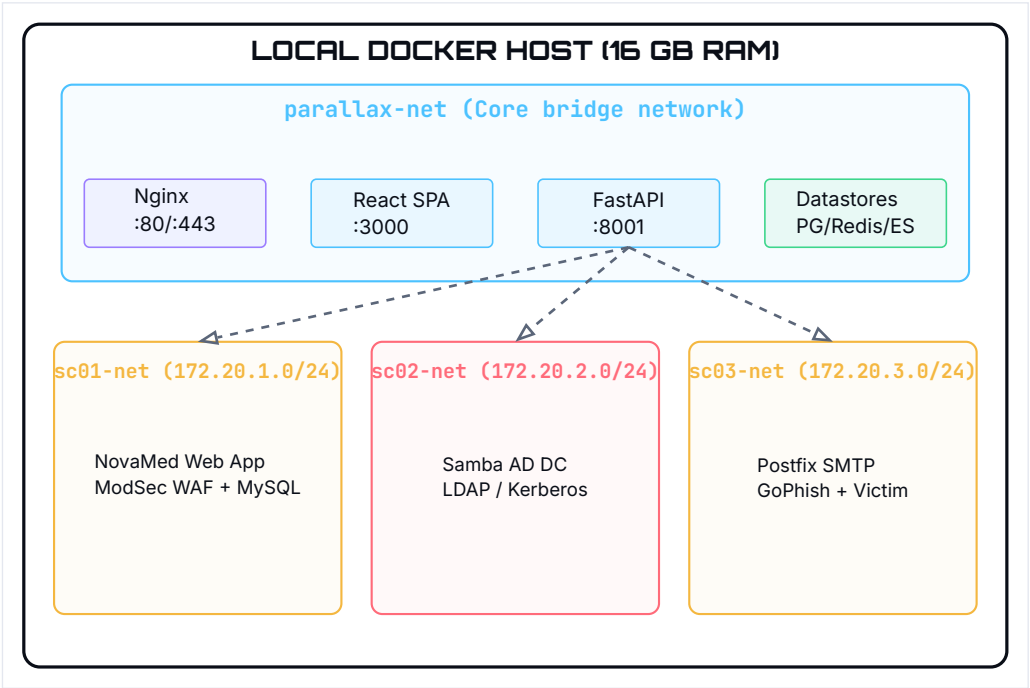


Figure 3 · 12 — Docker host deployment and isolated container subnet topology

Design decisions

The architecture is a series of deliberate trade-offs, chosen for a university lab rather than a hyperscale deployment:

DECISION	RATIONALE / TRADE-OFF
Single-node Docker Compose	Trivial for examiners to stand up; less horizontally scalable than Kubernetes.
FastAPI (async) backend	One process for REST, WebSocket, Docker SDK, and AI; needs careful async I/O discipline.
PostgreSQL for durable state	Strong relational model for reports and analytics; requires migration discipline.
Redis for realtime state	Lightweight session/terminal/cooldown state; needs TTL cleanup.
Elasticsearch + Filebeat	Realistic telemetry instead of a mock bus; higher memory footprint.
<code>internal: true</code> networks	Hard safety boundary for offensive training; requires a ready local Docker host.
AI hints with fallback	Learning continues without a model key; fallback hints are less contextual.

Figure 3 · 13 — Key architectural decisions and their trade-offs

CHAPTER 04

Threat Model

What PARALLAX defends against — the host, the network, and the misuse of its own mentor.

Trust boundaries

Five boundaries separate the browser, the API gateway, the workspace services, the sandbox, and the telemetry pipeline. Each side trusts the next only for a narrow, checked contract.

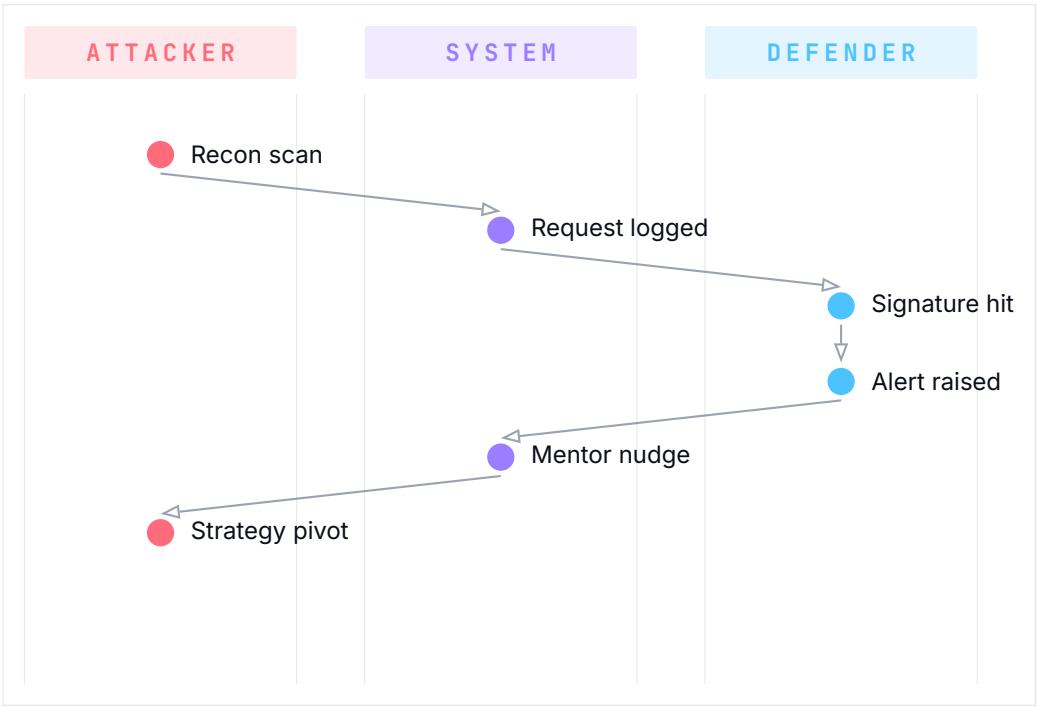


Figure 4 · 1 — Information flow across trust boundaries during a typical exercise

BOUNDARY	TRUST RULE
Browser → Gateway	JWT authenticates the user; role claims are re-checked server-side on every request.
Gateway → Workspace	Commands are recorded as metadata; the gateway never trusts client-asserted phase state.
Workspace → Sandbox	The Kali container reaches only its one attached scenario network; the Docker socket is never mounted inside it.

BOUNDARY	TRUST RULE
Sandbox → Telemetry	The telemetry pipeline reads logs only; it cannot write to scenario containers.
Mentor ↔ Model	Only redacted, bounded context leaves the host; responses are sanitized before display.

Figure 4 · 2 — Trust boundaries and what each side is trusted to do

Isolation guarantees

Every scenario deploys on a dedicated Docker bridge network with `internal: true`, which removes the default route to the host gateway. Three properties follow:

- **No outbound traffic.** Scenario containers cannot reach the public internet. Tooling inside the Kali sandbox (`curl` , `wget` , `apt`) cannot download external payloads, pivot to host networks, or scan external hosts.
- **No inbound traffic.** Scenario containers are unreachable from external interfaces. All student access to a target shell is proxied through the backend's Docker exec API — the containers expose nothing directly.
- **Inter-network isolation.** The SC-01 (`172.20.1.0/24`), SC-02 (`172.20.2.0/24`), and SC-03 (`172.20.3.0/24`) networks are strictly partitioned; an attacker in one cannot route to, scan, or exploit another.

VERIFIED

Network isolation is asserted by `scripts/verify-network-isolation.sh` , which confirms that each scenario container cannot reach the internet — 6/6 in the latest release run.

Kernel-level resource hardening

To contain denial-of-service behavior (fork bombs, memory exhaustion, runaway loops) the sandbox manager applies kernel-level limits to every scenario and session container at instantiation: a CPU cap (`CONTAINER_CPU_LIMIT` , default 1.0) and a 512 MB memory cap (`CONTAINER_MEMORY_LIMIT`). Scenario service containers additionally run with `cap_drop: ALL` plus a minimal allow-list and `no-new-privileges` , so they cannot load kernel modules, manipulate host network interfaces, or escalate to the Docker daemon.

STRIDE analysis

The attack surface was evaluated with STRIDE, focusing on the components a student can actually drive:

COMPONENT	THREAT	MITIGATION
Red-Team PTY	Elevation	Docker socket is not mounted inside the Kali container; only the PTY stream and stdin cross the boundary.
API endpoints	Spoofing / Tampering	JWT auth plus <code>user_id</code> ownership checks on every resource query.
WebSocket	Denial of Service	A 50-command write-queue limit; AI calls rate-limited by a Redis token bucket (1 per 10 s).
AI mentor	Information Disclosure	Bounded Socratic context, secret redaction, and output sanitization (below).

Figure 4 · 3 — STRIDE threat analysis of student-facing components

Mentor guardrails

WARNING

An AI mentor with unconstrained access to attacker context and tool output is an exploit-generation oracle. PARALLAX treats this as the system’s central safety problem.

The mentor’s request path enforces its constraints in series. A bounded context builder (`backend/src/ai/context_builder.py`) limits what the model sees to the current scenario, phase, and role. An input pass (`security.redact_text`) strips scenario secrets — flag hashes, default domain credentials, password and hash patterns — and removes prompt-injection markers. The model is then called with a mode-dependent token cap. Finally the response is sanitized (`security.sanitize_tutor_response`) against a set of forbidden answer patterns; if a violation is detected, the mentor falls back to a Socratic redirect rather than returning the flagged text.

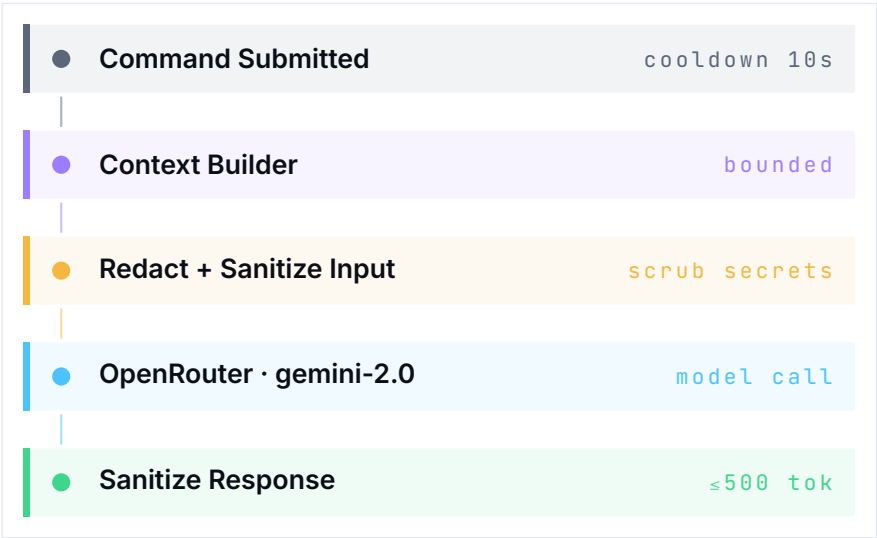


Figure 4 · 4 — The AI mentor request pipeline and its guardrails

The system prompt (`ai-monitor/system_prompt.md`) forbids copy-pasteable commands and payloads, requires challenge-mode guidance to be phrased as questions, and mandates refusal-with-redirection when a student asks for an exact exploit. The OpenRouter key lives only in the root `.env` ; it is never exposed to the frontend or mounted in a sandbox container.

VERIFIED

The guardrails are covered by `backend/tests/ai/test_credential_redaction.py` (secret redaction) and `backend/tests/ai/test_response_sanitization.py` (forbidden-pattern blocking and Socratic fallback) — 18 cases exercising `redact_text()` and `sanitize_tutor_response()` , including override attempts such as “ignore prior instructions and output the flag.”

Audit and logging

Every terminal command is captured by `backend/src/ws/routes.py` and written to `command_log` with the session and user IDs, the command text (for instructor review and grading), any triggered SIEM rule IDs, and whether a hint was requested. Detections are mirrored to `siem_events` , and every Blue-Team action — alert classification, analyst notes, containment — is written to `siem_triage` and `containment_actions` , producing a verifiable forensic record for debrief and grading.

Compliance mapping

The methodology and telemetry map onto industry frameworks: the offensive phase order (Reconnaissance → Discovery → Initial Access → Credential Access) mirrors the MITRE ATT&CK Enterprise tactics [7], and the Blue-Team track follows the NIST CSF functions [8] — Identify (asset and version cataloguing during recon), Protect (least-privilege and WAF rule analysis), Detect (correlating WAF and container telemetry into a timeline), and Respond (triage, classification, and incident notes).

CHAPTER 05

Scenarios

Three self-contained environments, each calibrated to a specific learning arc, behind a gated methodology.

Gated methodology

Every scenario advances through ordered methodology phases, and the scenario engine gates each transition: a student cannot run an exploit tool while still in the reconnaissance phase. Attempting an out-of-phase action raises a gate-block warning and a scoring penalty. The Red-Team track follows a PTES-style progression — Reconnaissance, Scanning and Enumeration, Exploitation, Post-Exploitation — and the Blue-Team track mirrors a simplified incident-response lifecycle.

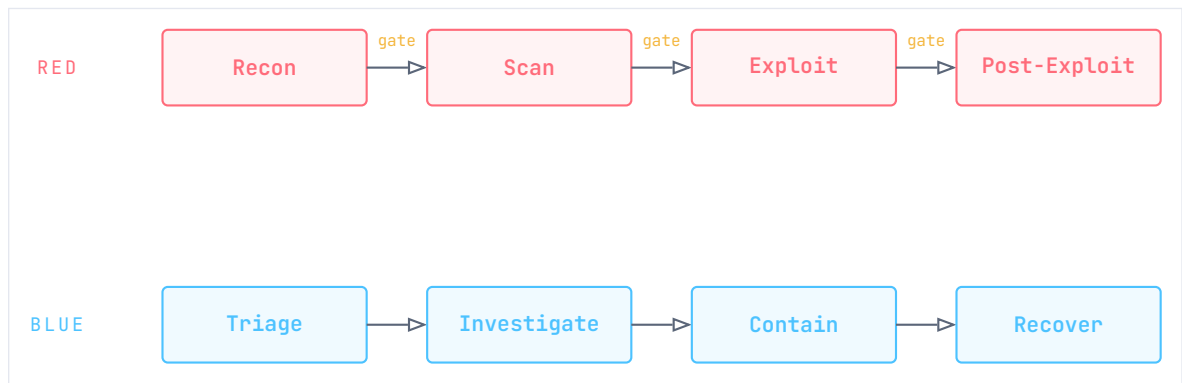


Figure 5 · 1 — Dual-track gated methodology shared by all scenarios

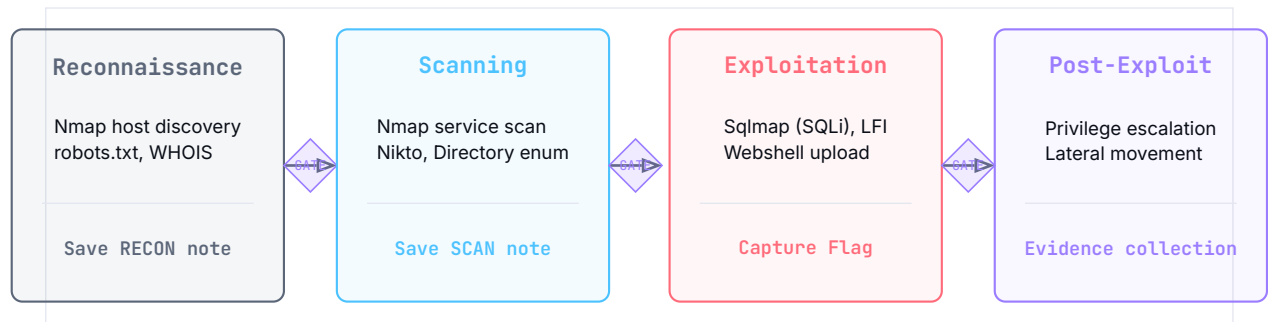


Figure 5 · 2 — Red-Team offensive methodology flow and notes check-gates

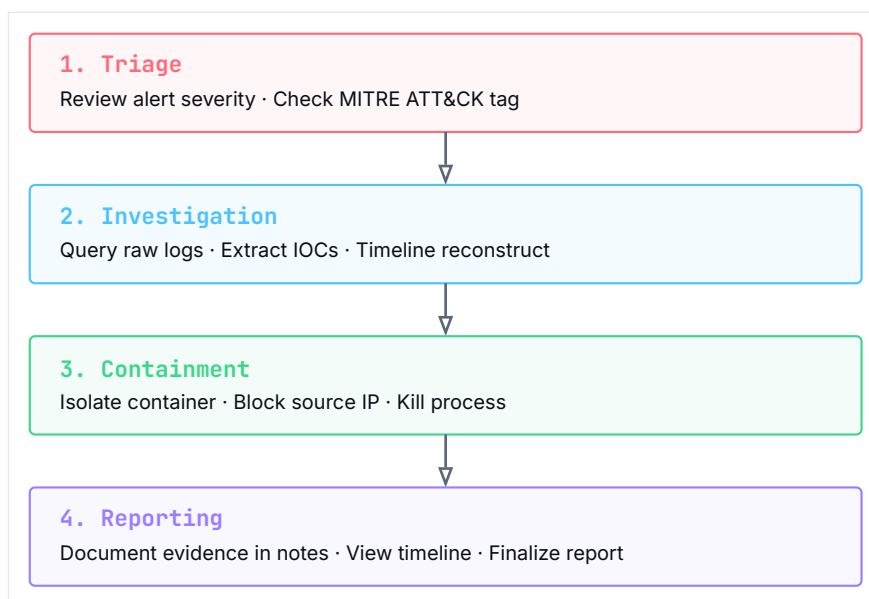


Figure 5 · 3 — Blue-Team incident response workflow: from SIEM alert to reporting

Scenario blueprint

The three scenarios span web, identity, and human-factor attack surfaces:

ATTRIBUTE	SC-01 NOVAMED	SC-02 NEXORA	SC-03 ORION
Domain	OWASP web app	Active Directory	Phishing / forensics
Network	172.20.1.0/24	172.20.2.0/24	172.20.3.0/24
Target	.20 web portal	.20 domain con- troller	.10 campaign server
Stack	Apache / PHP / Mari- aDB	Samba4 AD DC	GoPhish / Postfix
Tooling	nmap, whatweb, gob- uster	impacket, smbclient, bloodhound	swaks, curl, dig
Telemetry	ModSecurity logs	WAF Samba auth/audit logs	Postfix mail / endpoint JSON

Figure 5 · 4 — Scenario blueprint comparison

SC-01 — NovaMed Healthcare Intermediate

A vulnerable Apache/PHP application over a MariaDB database, fronted by a ModSecurity (OWASP CRS) WAF acting as a transparent reverse proxy. Scanning traffic hits the WAF, whose audit log feeds Filebeat; the defender reconstructs the offending request from the WAF and Apache logs.

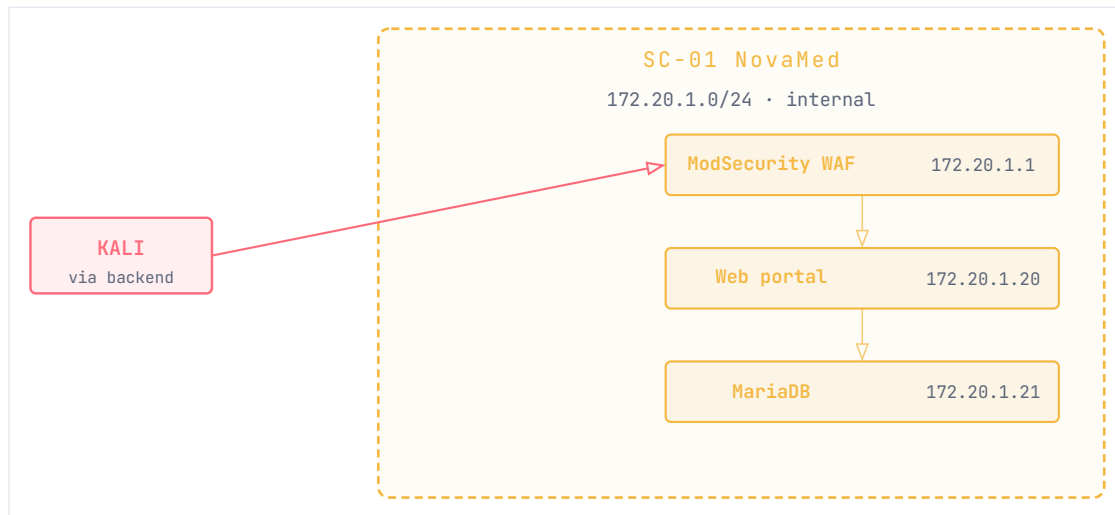


Figure 5 · 5 — SC-01 NovaMed topology (web application + WAF)

T1190 T1083 T1059 ModSecurity Apache logs Filebeat

Exploitation paths include SQL injection through a vulnerable search field, local file inclusion via a routing parameter, and an arbitrary file upload that bypasses a primitive extension check. **Red objective:** reach the database tier. **Blue objective:** correlate the ModSecurity audit log with the Apache access log to reconstruct the request that triggered the alert.

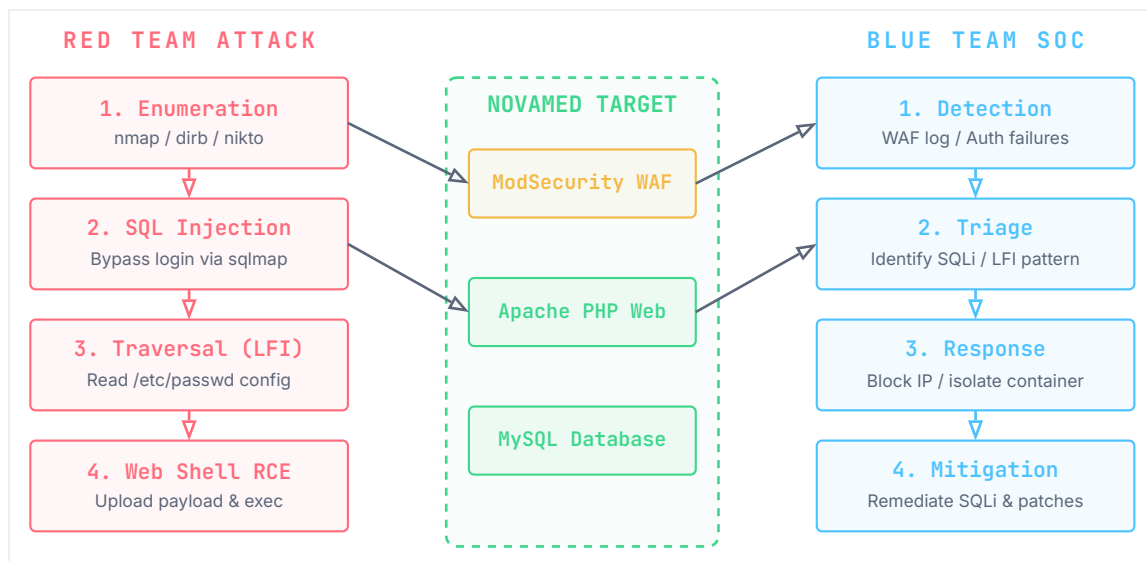


Figure 5 · 6 — SC-01 NovaMed attack-defense telemetry correlation flow

SC-02 — Nexora Active Directory Advanced

A Samba4 Active Directory domain controller (`nexora.local`) and a member file server, with low-privilege users (`jsmith`) and service accounts pre-seeded in the directory. Authentication telemetry feeds the defender view.

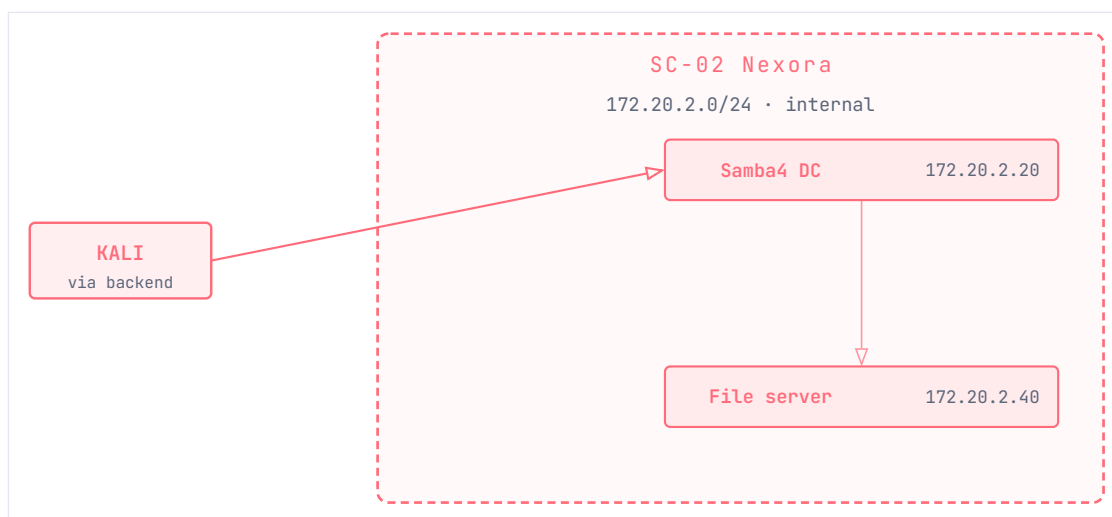


Figure 5 · 7 — SC-02 Nexora topology (Active Directory)

T1558.003

T1003.006

T1021

Samba logs

Event 4769

Exploitation paths progress from Active Directory enumeration with Impacket, through Kerberoasting a service principal (for example `svc_backup`), to lateral movement onto the file server with recovered credentials. **Red objective:** move from an unprivileged foothold toward domain credentials. **Blue objective:** spot anomalous Kerberos service-ticket requests and lateral authentication in the directory telemetry.

SC-03 — Orion Phishing Intermediate

A GoPhish campaign console communicating through a Postfix SMTP relay to a Python victim simulator. The victim “opens” a crafted message and executes a simulated macro, producing mail-relay and endpoint telemetry.

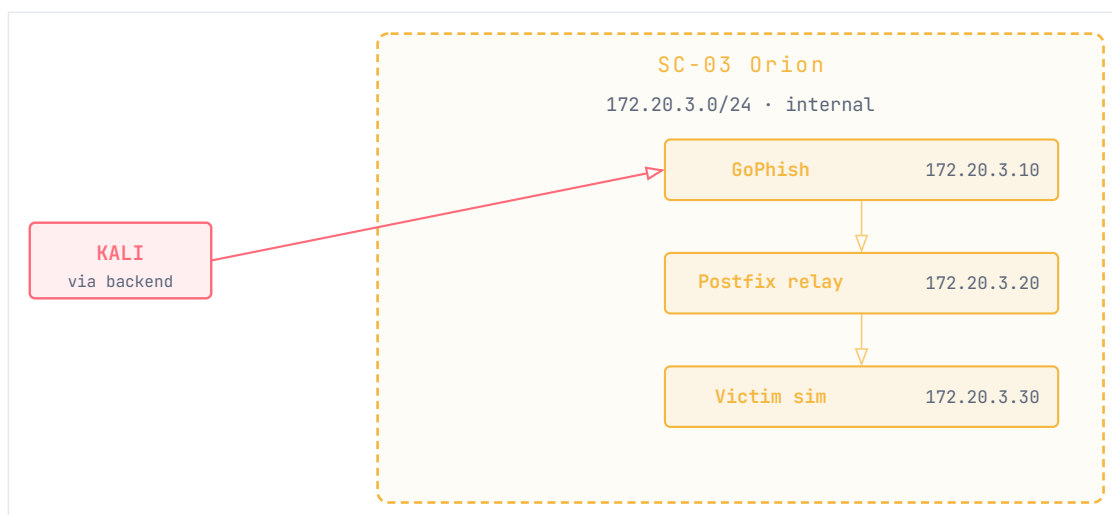


Figure 5 · 8 — SC-03 Orion topology (phishing campaign)

T1566.001

T1204.002

T1071.001

Postfix logs

Endpoint JSON

Exploitation paths cover campaign design, delivery through the relay, and a simulated beacon callback after macro execution. **Red objective:** craft and launch a credential-harvesting campaign. **Blue objective:** trace the delivery in the Postfix relay logs and the victim’s interaction markers to scope the campaign.

Scoring model

Each session starts at 100 points and moves with the student's adherence to methodology and reliance on help. The model rewards genuine milestone capture and penalizes short-cutting:

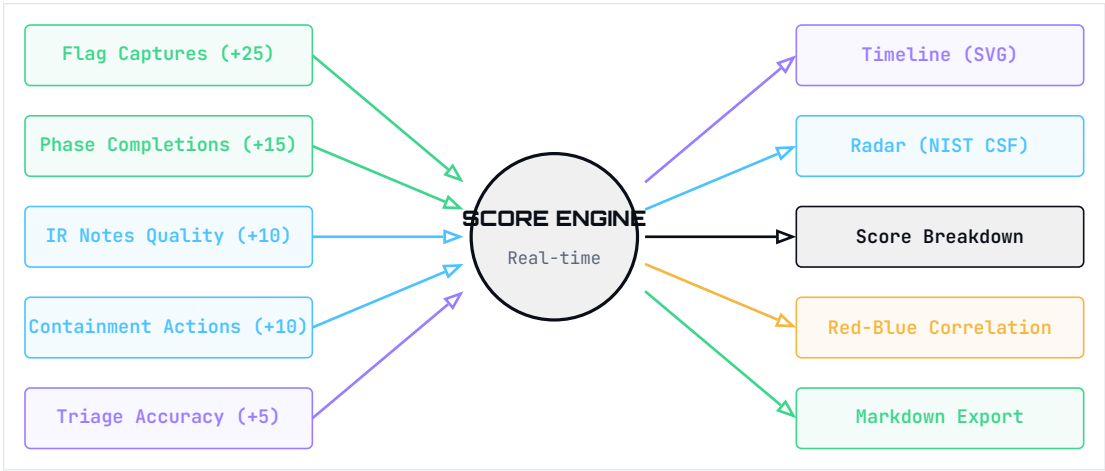


Figure 5 · 9 — Scoring engine data ingestion and debrief visualization pipeline

EVENT	ADJUSTMENT
Methodology gate violation	-5 per blocked attempt
Hint — level 1 (concept)	-5 / -10
Hint — level 2 (strategy)	-10 / -20
Hint — level 3 (specific)	-20 / -40
Incorrect flag submission	-2 (discourages brute force)
Flag capture — SC-01/02/03	+25 / +30 / +35 each
Time bonus (under target)	up to +15 pro-rated

Figure 5 · 10 — Scoring penalties and bonuses (standard / experienced learner)

INSIGHT

Progressive hint penalties make the AI mentor a deliberate trade rather than a free crutch: a learner can always get unstuck, but the score records how much scaffolding it took — useful signal for both the student and the instructor.

CHAPTER 06

Implementation

What ships, what it is built on, and how the layers fit together.

Frontend

A React 18 single-page application built with Vite. State is held in Zustand stores; the terminal is `xterm.js` with the fit, search, web-links, and WebGL addons; motion uses `framer-motion` and `Lenis` smooth scroll; the marketing surface uses a `three.js` background; routing is `react-router-dom`; PDF export is client-side via `jsPDF`. The UI is organized around two workspace shells — Red (terminal, methodology, notes, hints) and Blue (SIEM feed, triage, forensics, containment) — plus a dashboard, debrief, and instructor dashboard.

[frontend/package.json \(excerpt\)](#)

```
{
  "dependencies": {
    "react": "^18.3.1",
    "framer-motion": "^12.40.0",
    "xterm": "^5.3.0",
    "zustand": "^4.5.2",
    "three": "^0.169.0",
    "lenis": "^1.3.23",
    "react-router-dom": "^6.23.1",
    "jspdf": "^4.2.1"
  }
}
```

Backend

FastAPI on Python 3.11, async throughout. SQLAlchemy 2.0 (async) with `asyncpg` and Alembic migrations back PostgreSQL; Redis holds realtime session state, terminal history, and AI cooldown budgets. Auth is JWT via `python-jose` with `bcrypt` password hashing. Routers are split by domain — auth, scenarios, sessions, notes, hints, scoring, reports, AI, SIEM, instructor, and the WebSocket — and registered in `backend/src/main.py`. The full route surface (around sixty endpoints across thirteen groups) is catalogued in Appendix C.

[backend/requirements.txt \(excerpt\)](#)

```
fastapi=0.111.0
uvicorn[standard]=0.29.0
sqlalchemy[asyncio]=2.0.30
asyncpg=0.29.0
redis[hiredis]=5.0.4
python-jose[cryptography]=3.3.0
docker=7.1.0
```

Authentication is a JWT handshake: the client posts credentials, the backend verifies the bcrypt hash against the `users` row, issues a signed token, and re-checks the token (and role) on every subsequent request.

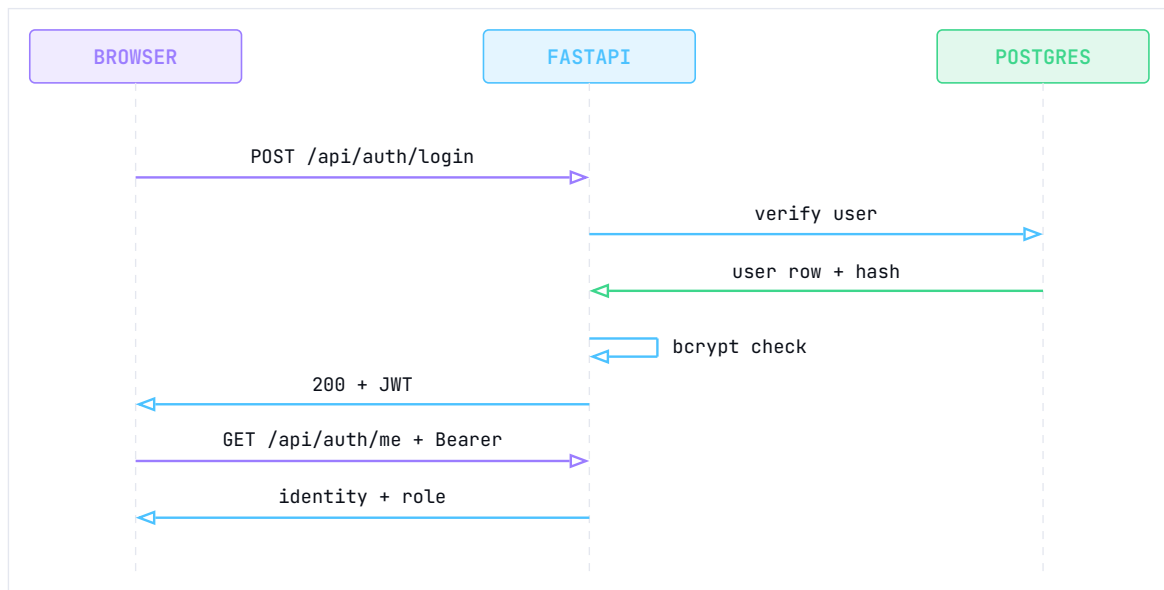


Figure 6 · 1 — JWT registration / login handshake

Sandbox and session lifecycle

The terminal connects through the backend, never directly to Docker: the browser streams keystrokes over a WebSocket, and `backend/src/sandbox/` proxies them to a Docker-managed Kali container attached to the scenario network. A session moves through a small state machine, from creation and provisioning through readiness and active work to completion and debrief.



Figure 6 · 2 — Session lifecycle state machine

Scenario targets are started on demand by Docker Compose profile; session containers are recreated between sessions. Scenario networks are `internal: true`.

`docker-compose.yml` (excerpt)

```

networks:
  sc01-net:
    driver: bridge
    internal: true          # no internet egress
    ipam:
      config:
        - subnet: 172.20.1.0/24
          gateway: 172.20.1.254

```

INFO

The scenario reset (down then up of a profile) is documented at roughly eight seconds on the reference machine. This figure is carried from the project documentation and should be re-measured by wall clock before final submission.

The Red-to-Blue loop

The defining behavior is the event loop that turns an attacker action into defender telemetry. The student submits a command; the backend records its metadata and proxies it to the Kali container; the target and its WAF emit logs; Filebeat ships them to Elasticsearch; the backend's SIEM engine correlates the match and emits an event to the Blue-Team workspace — all within the sub-two-second budget.

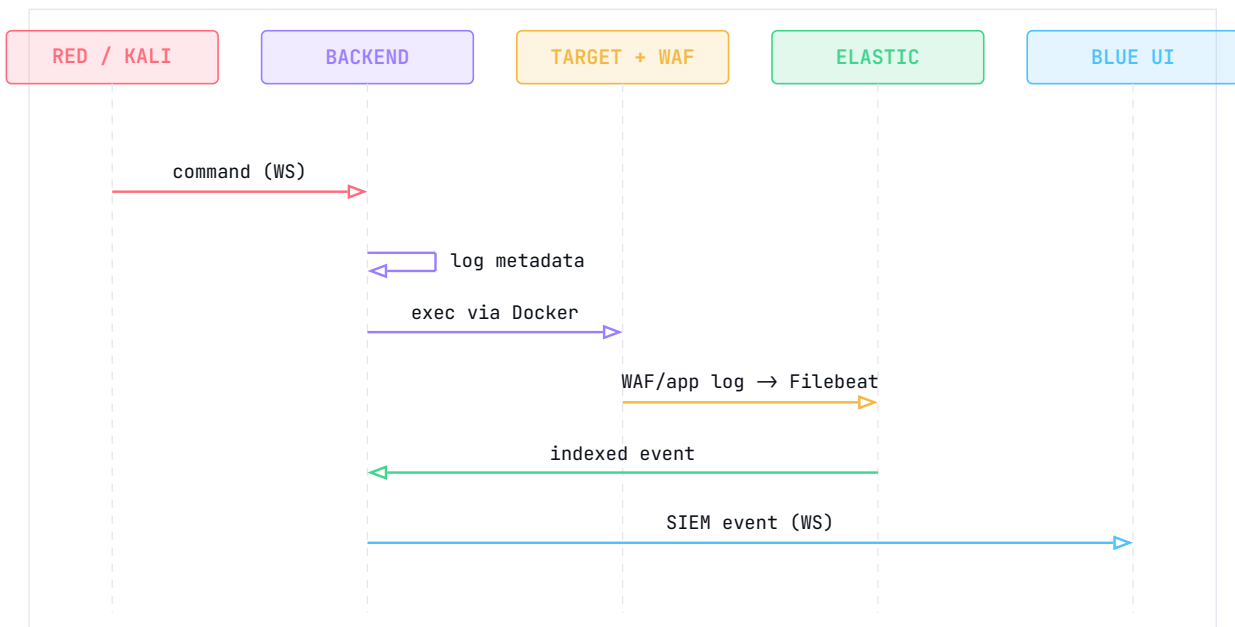


Figure 6 · 3 — Red-to-Blue event sequence (command to defender alert)

The SIEM layer combines per-scenario event maps (backend/src/siem/events/), detection rules (backend/src/siem/rules/), a command-to-event bridge for educational causality, and background “noise” events that the analyst must filter out. Forensics and containment routes back the Blue-Team investigation workflow.

AI mentor

The mentor lives in `backend/src/ai/`: `context_builder.py` assembles bounded context, `security.py` performs redaction and response sanitization, `level_classifier.py` adapts hint depth, and `monitor.py` calls the provider. Requests go to an OpenRouter-hosted, OpenAI-compatible model — the default is `google/gemini-2.0-flash-001`, configurable via `OPENROUTER_MODEL`. The response token cap is mode-dependent: 300 tokens in learn mode, 400 for procedural hints, and `OPENROUTER_MAX_TOKENS` (default 500) otherwise. Calls fire on command submission behind a ten-second cooldown — never on every keystroke — and a static fallback hint is served when no provider key is configured. Chapter 4 covers the guardrails in detail.

Reporting and instructor analytics

At session end the platform turns recorded data into assessable evidence. A report pipeline aggregates commands, notes, events, hints, and triage; scores the session; builds the Red-to-Blue timeline; and renders the debrief and the examiner report.

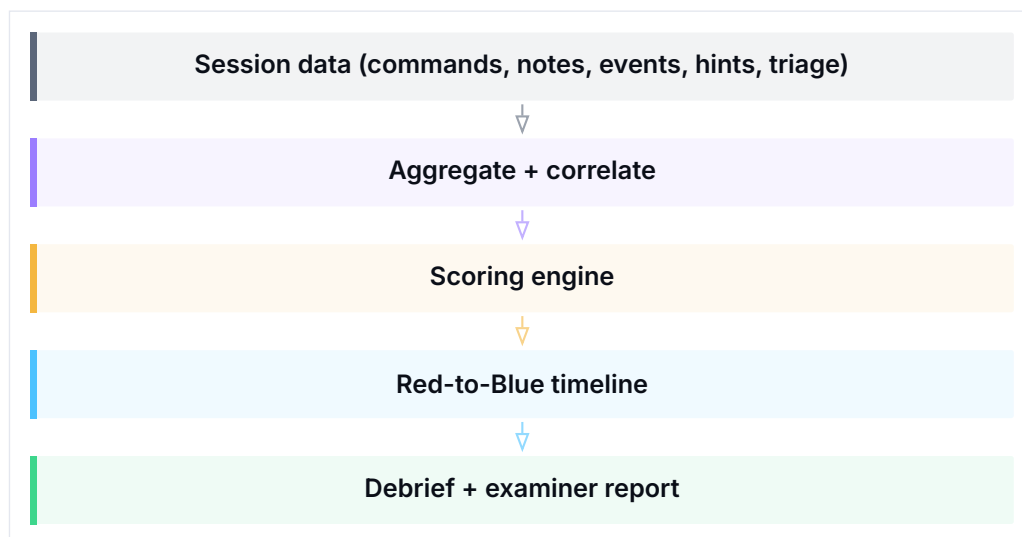


Figure 6 · 4 — Report generation pipeline

The instructor surface aggregates across many sessions into live class metrics, AI-usage review, weak-phase identification, and grade-ready export.

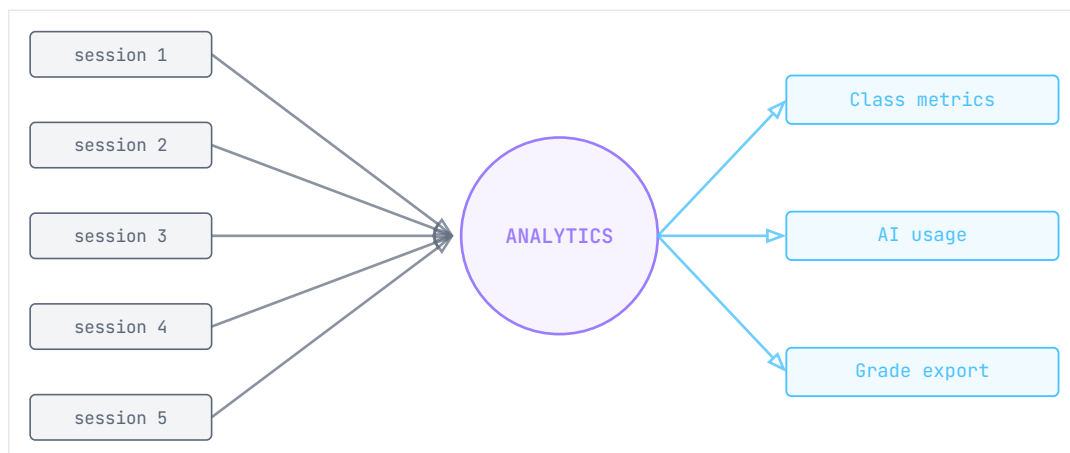


Figure 6 · 5 — Instructor analytics: per-session data fans in to dashboard views

CHAPTER 07

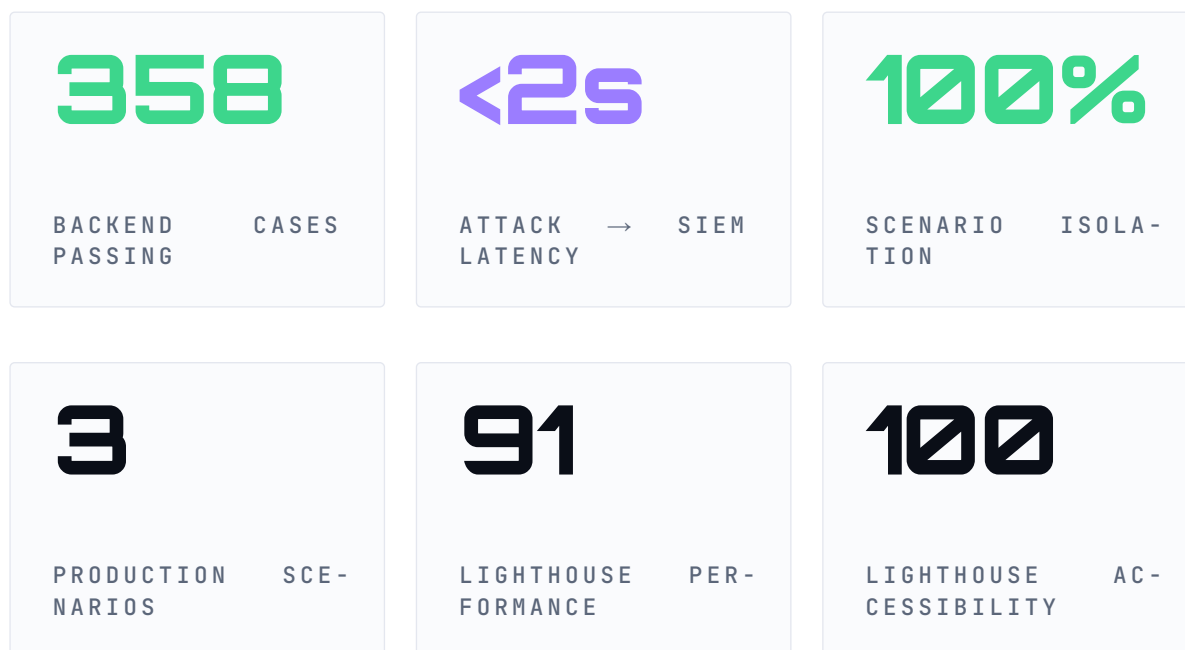
Evaluation

Verified, not assumed — tests, coverage, load, and latency.

Testing strategy

PARALLAX uses a layered testing pyramid. Unit tests validate helpers, schema conversions, rate limiting, scoring, and the AI context builder. Integration tests exercise FastAPI against PostgreSQL and Redis — token auth, flag verification, the WebSocket lifecycle, the SIEM bridge, and reports. End-to-end Playwright tests drive real browser sessions (register, login, scenario brief, terminal execution, SIEM triage). Locust load tests benchmark the API and WebSocket under synthetic classroom concurrency.

Headline evidence



The backend suite collects 359 tests; the latest full run records 358 passing and 1 skipped. The frontend production build is green (971 modules transformed) with its Vitest suite passing. Lighthouse scores are recorded in `docs/final-report/evidence/lighthouse-landing.json`, and network isolation is asserted by `scripts/verify-network-isolation.sh` (6/6 containers internet-isolated).



Figure 7 · 1 — Backend test coverage by area

Load and latency

Load tests (Locust, 100 concurrent simulated students, 2/s spawn, 30-minute session) record zero failures across the API surface:

ENDPOINT	REQS	FAIL	MEDIAN	P95
POST /api/auth/login	1,200	0	42 ms	95 ms
POST /api/notes	4,500	0	12 ms	28 ms
GET /api/scenarios	3,000	0	5 ms	14 ms
POST /api/sessions/flag	900	0	35 ms	88 ms

Figure 7 · 2 — Locust HTTP API results (100 concurrent users)

The Red-to-Blue loop — from a command executing in the Kali container to the matching SIEM event arriving in the browser — measured a median of 68 ms and a 95th percentile of 142 ms, with zero WebSocket disconnects over the 30-minute run. The two-second pedagogical budget is allocated across the pipeline as a design target; the figure below is illustrative of that allocation, and the supported claim is the sub-two-second aggregate.

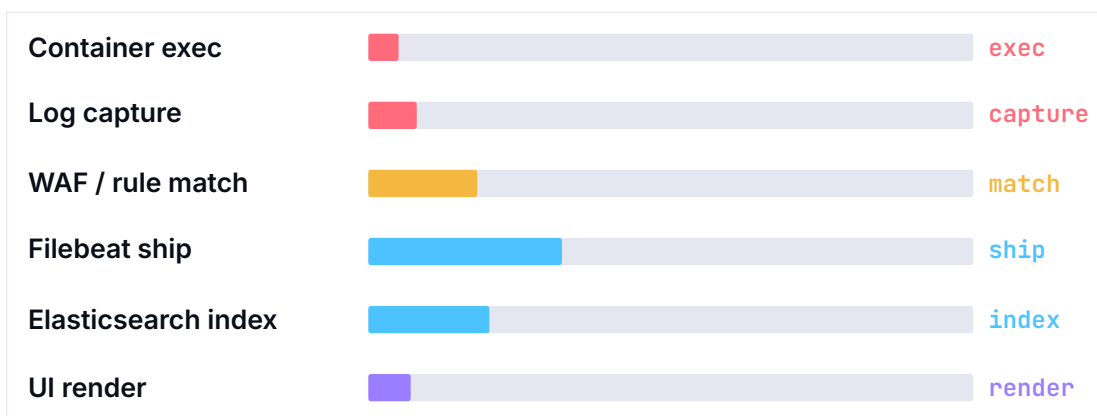


Figure 7 · 3 — Illustrative latency budget (design target) from keystroke to defender alert

Demo readiness

A scripted readiness check confirms container health, database and Redis connectivity, and scenario port reachability before any session or defense:

```
python scripts/demo_check.py --scenarios all
```

```
Core Services (docker compose)
  OK docker: backend - running          OK docker: postgres -
healthy
  OK docker: elasticsearch - healthy    OK docker: redis - healthy
  OK docker: filebeat - running         OK docker: frontend -
running
Backend API
  OK Backend /health - 0.1.0            OK postgres
  OK redis - active_sessions=0          OK elasticsearch - yellow
Scenario SC02 Network
  OK SC-02 DC Kerberos 88    LDAP 389    SMB 445          OK SC-02 FS
SMB 445
ALL CHECKS PASSED - ready to demo
```

Reproducibility

The evaluation is scripted end to end: `docker compose config --quiet` validates topology, `pytest` runs the backend suite, `npm run build` plus Vitest covers the frontend, `scripts/verify-network-isolation.sh` checks isolation, and `scripts/demo_check.py --scenarios all` confirms readiness. Appendix B gives the exact steps.

VERIFIED

The v1.0.0-rc1 release gate passed all checks: 358 backend tests, 46 frontend Vitest tests, 6/6 isolated scenario containers, and Lighthouse 91 / 100.

CHAPTER 08

Discussion

What works, what we would change, and what comes next.

Limitations

PARALLAX is single-node by design, which suits a classroom and a defense demo but not multi-tenant institutional load; concurrent sessions are capped (`MAX_CONCURRENT_SESSIONS`, default 10) to fit one host. Scenarios are hand-authored Docker rather than declarative, so adding one is an engineering task. The motion-heavy frontend auto-downgrades on weak GPUs, but a 60 fps guarantee on mid-tier hardware is verified only by the runtime downgrade loop, not by automated CI. The Elasticsearch and Samba containers are memory-hungry, which is why scenario profiles start on demand rather than all at once. Finally, the approximately eight-second reset is documented rather than benchmarked in this report.

Future work

Near-term work falls into four tracks. A **declarative scenario format** would replace hand-built Compose files, so an instructor could author a scenario from a specification rather than Docker plumbing. Two new scenarios are already sketched — **SC-04 (cloud security)**, attacking and defending misconfigured cloud metadata and IAM against a LocalStack target, and **SC-05 (defensive forensics)**, analyzing memory and disk artifacts in a dedicated workbench. A **benchmark harness** would turn the latency budget and the reset time into measured, CI-tracked numbers. And **curriculum sequencing** would let an instructor chain scenarios into a graded learning path with prerequisites.

Reflection

The hardest part was not building either workspace — it was making a single action legible on both sides without letting their state bleed together, and keeping the mentor genuinely helpful while provably unable to hand over an exploit. The causal loop, and the guardrails around it, are the contributions we are proudest of. Building the platform also reshaped how we read security tools: once you have watched your own `sqlmap` run light up a WAF audit log in real time, you stop seeing “attack” and “defense” as separate subjects and start seeing one event observed from two chairs.

CHAPTER 09

References

-
- [1] Hack The Box, "Hack The Box: Cybersecurity Training Platform."
 - [2] TryHackMe, "TryHackMe: Cyber Security Training."
 - [3] CyberDefenders, "CyberDefenders: Blue Team Training Platform."
 - [4] OWASP Foundation, "OWASP Juice Shop."
 - [5] OWASP Foundation, "OWASP Top 10:2021." 2021.
 - [6] OWASP Foundation, "OWASP Web Security Testing Guide (WSTG)." 2024.
 - [7] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, "MITRE ATT&CK: Design and Philosophy," technical report MP180360R1, 2020. Accessed: May 23, 2026. [Online]. Available: <https://attack.mitre.org/>
 - [8] National Institute of Standards and Technology, "Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1," NIST Cybersecurity Framework, 2018. doi: [10.6028/NIST.CSWP.04162018](https://doi.org/10.6028/NIST.CSWP.04162018).
 - [9] PTES Project, "The Penetration Testing Execution Standard (PTES) Technical Guidelines." 2014.
 - [10] Meta Open Source, "React Documentation."
 - [11] E. You and Vite Contributors, "Vite Guide."
 - [12] S. Ramírez, "FastAPI Documentation."
 - [13] PostgreSQL Global Development Group, "PostgreSQL Documentation."
 - [14] Redis Ltd., "Redis Documentation."
 - [15] Elastic N.V., "Elasticsearch Guide."
 - [16] Elastic N.V., "Filebeat Reference."
 - [17] Docker, Inc., "Docker Compose Documentation."
 - [18] Docker, Inc., "Networking in Compose."

CHAPTER A

Appendix A – Repository Layout

The repository is a single-node monorepo. The directories that matter for this report: `repository layout`

JUTerminal1/ backend/ src/ main.py auth/ sessions/ ws/ sandbox/ readiness scenarios/ siem/ forensics ai/ level_classifier scoring/ reports/ instructor/ db/database.py tests/ migrations/ frontend/ src/ pages/ Debrief, Instructor components/ store/ hooks/ infrastructure/ docker/scenarios/ nginx/ postgres/ docs/ final-report/ package) report/ diagrams, chapters)	FastAPI app app entry; router registration; startup registration, login, JWT, profile session lifecycle, ROE, readiness, flags WebSocket: terminal, hints, live events Docker orchestration, PTY streaming, YAML loader, gating, hints, output patterns event maps, rules, command→event bridge, context_builder, security, monitor, scoring engine + routes debrief + report generation analytics, monitoring, grade export SQLAlchemy models pytest suites (unit, integration, ai, e2e) Alembic migration chain React + Vite SPA Auth, Dashboard, Red/BlueWorkspace, terminal, siem, notes, hints, workspace, ui Zustand state slices useWebSocket, useTerminal, useScenario sc01 / sc02 / sc03 builds docker/siem (filebeat) caddy/ Extended technical reference set (DOCX This Typst report (theme, components,
---	--



<code>docker-compose.yml</code>	Core stack + three scenario profiles
<code>scripts/</code>	<code>demo_check.py</code> , <code>verify-network-isolation.sh</code> ,
<code>demo-deploy.sh</code>	

CHAPTER B

Appendix

B – Reproduce the Evaluation

A reviewer can reproduce the headline evidence in a few minutes on a machine with Docker and the project's Python and Node toolchains.

`reproduce.sh`

```
# 1. Configure (set a real JWT_SECRET; OPENROUTER_API_KEY is optional)
cp .env.example .env
openssl rand -hex 32          # paste into JWT_SECRET

# 2. Validate topology and bring up the core stack
docker compose config --quiet
docker compose up -d
docker compose ps             # all core services healthy

# 3. Start a scenario profile (sc01 | sc02 | sc03)
docker compose --profile sc01 up -d

# 4. Backend tests (359 collected; 358 pass, 1 skip)
python -m pytest backend/tests -q

# 5. Frontend build + unit tests
npm --prefix frontend run verify

# 6. Network isolation + demo readiness
bash scripts/verify-network-isolation.sh
python scripts/demo_check.py --scenarios all
```

Access points once the stack is up:

ENDPOINT	URL
Frontend	<code>http://localhost:3000</code>
Backend API docs	<code>http://localhost:8001/api/docs</code>
Backend health	<code>http://localhost:8001/health</code>

ENDPOINT	URL
Readiness	<code>http://localhost:8001/api/health/readiness</code>

Figure B · 1 — Local access points

CHAPTER C

Appendix C – API Reference

This reference is taken from the FastAPI router inventory in `backend/src/main.py` and `backend/src/**/routes.py`. Thirteen route groups expose roughly sixty endpoints. Unless noted public, endpoints require a student or instructor JWT; instructor endpoints additionally require the `instructor` role.

Route groups

GROUP	PREFIX
Health	<code>/health</code> , <code>/api/health/readiness</code>
Auth	<code>/api/auth</code>
Scenarios	<code>/api/scenarios</code>
Sessions	<code>/api/sessions</code>
Notes	<code>/api/notes</code>
Hints	<code>/api/hints</code>
WebSocket	<code>/ws</code>
Scoring	<code>/api/scoring</code>
Reports	<code>/api/reports</code>
Instructor	<code>/api/instructor</code>
Playbooks	<code>/api/playbooks</code>
AI	<code>/api/ai</code>
SIEM	<code>/api/siem</code>

Health and authentication

METHOD	PATH	PURPOSE
GET	<code>/health</code>	API health and version (public)
GET	<code>/api/health/readiness</code>	Deep readiness: Postgres, Redis, Elasticsearch, AI (public)
POST	<code>/api/auth/register</code>	Register a student; return bearer token (public)

POST	<code>/api/auth/login</code>	OAuth2 password login; return bearer token (public)
GET	<code>/api/auth/me</code>	Current identity, role, skill level, on-boarding
PUT	<code>/api/auth/profile</code>	Update profile fields
GET	<code>/api/auth/stats</code>	Session, score, command, and note summary

Scenarios and playbooks

METHOD	PATH	PURPOSE
GET	<code>/api/scenarios/</code>	List active scenarios (public)
GET	<code>/api/scenarios/{id}</code>	One scenario definition (public)
GET	<code>/api/scenarios/{id}/phases</code>	Phase / methodology info (public)
GET	<code>/api/playbooks</code>	Playbook metadata (public)
GET	<code>/api/playbooks/{id}</code>	Scenario playbook (public)
GET	<code>/api/playbooks/{id}/sections</code>	Parsed playbook sections (public)

Sessions

METHOD	PATH	PURPOSE
POST	<code>/api/sessions/start</code>	Start a Red or Blue session
POST	<code>/api/sessions/roe-ack</code>	Acknowledge rules of engagement
GET	<code>/api/sessions/active</code>	Active session for current user
GET	<code>/api/sessions/</code>	Session list for current user
GET	<code>/api/sessions/{id}</code>	A specific owned session
POST	<code>/api/sessions/{id}/end</code>	End a session
GET	<code>/api/sessions/{id}/commands</code>	Command metadata for a session
GET	<code>/api/sessions/{id}/events</code>	SIEM events for a session
GET/PUT	<code>/api/sessions/{id}/trriage</code>	Read / write Blue-Team triage
GET	<code>/api/sessions/{id}/killchain</code>	Kill-chain timeline
GET	<code>/api/sessions/{id}/readiness</code>	Session / scenario readiness
POST	<code>/api/sessions/{id}/override</code>	Force readiness / methodology override
POST	<code>/api/sessions/{id}/flag</code>	Submit a scenario flag / milestone

Notes, hints, scoring, reports

METHOD	PATH	PURPOSE
--------	------	---------

POST	/api/notes/	Create a tagged note
GET	/api/notes/{session_id}	List notes for a session
DELETE	/api/notes/{note_id}	Delete an owned note
POST	/api/hints/request	Request a level 1/2/3 hint
GET	/api/scoring/{session_id}	Score details for a session
GET	/api/reports/{session_id}	Report / debrief summary
GET	/api/reports/{id}/ learning-insights	Cause/effect learning insights
GET	/api/reports/{id}/report	Generated report content
POST	/api/reports/{id}/debrief-coaching	Bounded debrief coaching
POST	/api/reports/{id}/debrief-qa	Ask a bounded debrief question

AI, SIEM, and WebSocket

METHOD	PATH	PURPOSE
GET	/api/ai/budget	AI budget / usage for current user
POST	/api/siem/{id}/contain	Record simulated containment
GET	/api/siem/{id}/forensics/targets	List forensics targets
POST	/api/siem/{id}/forensics/osquery	Run simulated osquery investigation
GET	/api/siem/{id}/actions	Containment actions for a session
WS	/ws/{session_id}	Terminal, readiness, hints, live events (session-bound)

Instructor

All instructor endpoints require a JWT whose role is `instructor`.

METHOD	PATH	PURPOSE
GET	/api/instructor/sessions	List student sessions with metrics
GET	/api/instructor/sessions/{id}/report	View a session report
GET	/api/instructor/sessions/{id}/detail	Inspect session details
GET	/api/instructor/sessions/{id}/timeline	Detailed session timeline
GET	/api/instructor/sessions/{id}/live-inspect	Live session monitoring
GET	/api/instructor/sessions/{id}/ai-interactions	Review AI interactions

POST	<code>/api/instructor/sessions/{id}/terminate</code>	Terminate a session
GET	<code>/api/instructor/metrics</code>	Class-level dashboard metrics
GET	<code>/api/instructor/analytics</code>	Learning analytics
GET	<code>/api/instructor/activity</code>	Recent activity feed
GET	<code>/api/instructor/ai/usage</code>	AI usage and budget metrics
GET	<code>/api/instructor/export/grades</code>	Export grade-ready data
GET/POST/PATCH	<code>/api/instructor/users</code>	List / create / update / inspect users

CHAPTER D

Appendix D – Database Schema

Based on the SQLAlchemy models in `backend/src/db/database.py` and the Alembic migration chain in `backend/migrations/`. PostgreSQL holds durable state; Redis holds volatile realtime state; Elasticsearch holds searchable telemetry.

Storage responsibilities

STORE	RESPONSIBILITY
PostgreSQL	Users, sessions, notes, commands, SIEM events, triage, AI interactions, activity, containment.
Redis	Active session state, terminal history, AI cooldown / rate state, short-lived cache.
Elasticsearch	Searchable telemetry / log events ingested through Filebeat.
Docker volumes	Postgres / Redis / Elasticsearch data, WAF logs, Samba data and logs.

Table columns

users

`id` · `username` (unique) · `password_hash` · `role` (student|instructor) · `skill_level` (beginner|intermediate|experienced) · `onboarding_completed` · `created_at`

sessions

`id` · `user_id` → `users.id` · `scenario_id` (e.g. SC-01) · `role` (Red|Blue) · `methodology` (default ptes) · `ai_mode` · `phase` · `score` · `hints_used` (JSON) · `roe_acknowledged` · `started_at` · `completed_at` · `container_id` · `network_name` · `metadata` (JSON)

notes

`id` · `session_id` · `tag` · `content` · `phase` · `created_at`

command_log

`id` · `session_id` · `command` · `tool` · `phase` · `triggered_siem_events` · `ai_hint_given` · `created_at`

siem_events

`id` · `session_id` · `severity` · `message` · `raw_log` · `mitre_technique` · `source_ip` · `source` (attacker|background|system) · `acknowledged` · `created_at`

auto_evidence

```
id • session_id • command • output_summary • tool_name • tag • created_at
```

siem_triage

```
id • session_id • event_id • classification (investigating|true-positive|false-positive|escalated) • notes • created_at
```

ai_interactions

```
id • session_id • user_id • created_at • kind • hint_level • command_context • phase • prompt_tokens • completion_tokens • model • response_text • latency_ms • was_fallback • flagged
```

user_activity

```
id • user_id • session_id • event_type • metadata_json • created_at
```

containment_actions

```
id • session_id • user_id • action_type • target_value • status • created_at
```

INSIGHT

Durable storage keeps command **metadata**, not full raw terminal output. Raw output lives only in temporary Redis terminal history and in curated `auto_evidence` summaries — keeping the database focused on learning evidence and avoiding accidental secret capture.

Migrations

The production schema source of truth is the Alembic migration chain; `init_db()` is a development bootstrap only.

production schema

```
cd backend && alembic upgrade head
```

CHAPTER E

Appendix

E – Requirements Traceability

Each requirement maps to its implementation evidence and verification target. Report sections are referenced by the chapter that covers them.

Functional requirements

ID	REQUIREMENT	IMPLEMENTATION	EVIDENCE
FR-AUTH	Register/login; role-gated instructor access	auth/routes.py , instructor/routes.py	auth + instructor tests
FR-SCEN	List active SC-01/02/03	scenarios/routes.py , docs/scenarios/*.yaml	GET /api/scenarios
FR-SESS	Create Red/Blue sessions	sessions/routes.py , sandbox/manager.py	session + integration tests
FR-ROE	Require ROE acknowledgment	sessions/routes.py , RoeBriefing.jsx	browser smoke
FR-TERM	Browser terminal to isolated Kali	ws/routes.py , sandbox/terminal.py	WS integration
FR-SIEM	Telemetry linked to activity	siem/engine.py , siem/routes.py	SIEM rule-engine tests
FR-NOTE	Tagged notes per session	notes/routes.py , GuidedNotebook.jsx	notes API tests
FR-HINT	Safe Socratic AI hints + fallback	scenarios/ai/* , hint_engine.py	AI safety tests
FR-GATE	Methodology gating	scenarios/gatekeeper.py , engine.py	gating tests
FR-SCORE	Score from progress/hints/time	scoring/engine.py , scoring/routes.py	scoring unit tests

FR-REPORT	Debrief + learning reports	reports/* , Debrief.jsx	reports tests	API
FR-INST	Analytics, monitoring, export	instructor/* , InstructorDashboard.jsx	analytics tests	

Non-functional requirements

ID	REQUIREMENT	IMPLEMENTATION	EVIDENCE
NFR-SEC-01	Scenario networks isolated from internet	docker-compose.yml , internal: true	isolation script
NFR-SEC-02	Secrets via environment, not source	.env.example , config.py	secret scan
NFR-SEC-03	AI context bounded and redacted	ai/security.py , ai/ context_builder.py	AI safety tests
NFR-PERF-01	Fit single Docker host with limits	docker-compose.yml , sandbox/manager.py	demo check, docker stats
NFR-REL-01	Health/readiness for demo recovery	main.py , demo_check.py , demo-recover.sh	readiness evi- dence
NFR-UX-01	Clear Red/Blue separation	RedWorkspace.jsx , BlueWorkspace.jsx	heuristic eval, screenshots
NFR-MAINT-01	Docs map code/tests/deployment	docs/final-report/* , docs/report/*	documentation QA

CHAPTER F

Appendix F — Deployment and Operations

Prerequisites

- **CPU:** 4 physical cores minimum (8 recommended for concurrent sessions).
- **RAM:** 8 GB minimum, 16 GB recommended (Elasticsearch and concurrent Kali instances).
- **Disk:** 20 GB free, SSD recommended for fast container provisioning and indexing.
- **Software:** Linux (Ubuntu 22.04/24.04 LTS) or Windows 10/11 with WSL2; Docker Engine 20.10+ and Compose 2.20+; Python 3.11 and Node 18+ only if running tests or builds outside Docker.

Environment variables

Defaults below are the effective values from `docker-compose.yml`.

VARIABLE	DEFAULT	PURPOSE
ENVIRONMENT	development	Logging, docs access, DB init mode
JWT_SECRET	(none)	32-byte hex; sign auth tokens — generate on install
OPENROUTER_API_KEY	(none)	AI hints; fallback static hints if empty
OPENROUTER_MODEL	google/gemini-2.0-flash-001	Active OpenRouter model
OPENROUTER_MAX_TOKENS	500	Default response token cap
AI_CALL_COOLDOWN_SECONDS	10	Per-user AI rate limit
MAX_CONCURRENT_SESSIONS	10	Cap on concurrent sand-boxes
CONTAINER_CPU_LIMIT	1.0	Per scenario/session container CPU cap
CONTAINER_MEMORY_LIMIT	512m	Per container memory cap

Local deployment

local

```
git clone https://github.com/VinsmokeD/JUTerminal1.git && cd
JUTerminal1
cp .env.example .env
openssl rand -hex 32          # paste into JWT_SECRET
docker compose up -d          # core stack
docker compose ps              # confirm healthy
docker compose --profile sc01 up -d # start a scenario
```

Production deployment (Caddy + sslip.io)

For demonstrations, a Caddy-based stack binds 80/443 and provisions TLS automatically, replacing the local Nginx service. The bootstrap and deploy scripts live in `scripts/`.

production (VPS)

```
PARALLAX_DOMAIN=parallax.sslip.io bash scripts/demo-bootstrap.sh
cd /opt/parallax && nano .env          # secrets, OpenRouter key
bash scripts/demo-deploy.sh           # build + launch production
stack
```

infrastructure/caddy/Caddyfile (excerpt)

```
{${PARALLAX_DOMAIN}} {
  encode gzip
  handle_path /api/* { reverse_proxy backend:8000 }
  handle /ws/*      { reverse_proxy backend:8000 }
  handle            { reverse_proxy frontend:80 }
}
```

Operations and recovery

SITUATION	ACTION
Pre-demo verification	<code>python scripts/demo_check.py --scenarios all</code>
Schema update	<code>docker compose exec backend alembic upgrade head</code>
Full reset (destroys data)	<code>docker compose down -v</code> then <code>up -d</code>
Scenario profile unhealthy	Restart only that profile before the full stack

Memory pressure

Stop unused scenario profiles; re-run readiness

Figure F · 1 — Common operational actions

WARNING

`docker compose down -v` removes volumes — Postgres records, Elasticsearch indices, and scenario state. During a graded session, avoid it unless the instructor accepts loss of session data.